MDM GRC READINESS & CONTROL ASSURANCE CASE STUDY

MDM-D02

Stakeholder and RACI Matrix

Deliverable 2 of 15 in a portfolio case study on readiness and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company. Cross-references to other deliverables use their MDM-D numbers.

Prepared by
Ali Fathi Aldhabiki
Cybersecurity Governance, Risk & Compliance (GRC)
linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Notice
The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

Stakeholder and RACI Matrix

MDM-D02

Stakeholders

The roles below appear across this case study. All are part of the fictional organization; their input and approvals are simulated (MDM-D01, constraint CN-04).

Role	Responsibility in this case study	Appears in
CISO	Accountable for the assessment and its conclusions. Gives cybersecurity approval for access policy changes, owns MDM-CTL-005 and reviews the IT Operations Manager's administrative access.	MDM-D05, MDM-D07, MDM-D08, MDM-D14
GRC Analyst	Prepares the risk assessment, control requirements, evidence requests, tests and findings, and maintains the policy. Does not operate the service or approve and review access.	MDM-D04 to MDM-D06, MDM-D09 to MDM-D14
IT Operations Manager	Owns most operational controls. Approves and reviews the team's administrative access and receives escalations.	MDM-D05, MDM-D07, MDM-D08
IT Operations Team	Operates Intune and the mobile service: policies, offboarding, wipes and reports. Supplies technical evidence.	MDM-D07 to MDM-D09
Business Owner	Risk Owner for the mobile service risks. Approves access policy changes, risk treatment and residual risk acceptance.	MDM-D04, MDM-D05, MDM-D12
Enterprise IAM Team	Administers Conditional Access and emergency access accounts, and owns user MFA.	MDM-D08
Change Advisory Board (CAB)	Authorizes access policy changes before deployment.	MDM-D05, MDM-D06
Contractor Sponsor and Responsible Business Manager	The sponsor tracks each contractor's authorization, reports early departures and coordinates device return. The Responsible Business Manager approves extensions.	MDM-D06, MDM-D07
Line Manager	Approves an employee's request to join BYOD.	MDM-D06, MDM-D07

Role	Responsibility in this case study	Appears in
Internal Audit	Retests items the GRC Analyst prepared, so GRC never verifies its own work.	MDM-D12, MDM-D14
Employees and Contractors	Follow the policy, acknowledge the BYOD notice and report lost devices and incidents.	MDM-D06, MDM-D07

Assessment RACI

Activity	CISO	GRC Analyst	IT Operations Manager	IT Operations Team	Business Owner
Define the assessment scope, risks and control requirements.	A	R	C	C	C
Request and review supporting evidence.	A	R	I	C	I
Extract and submit the requested technical evidence.	I	C	A	R	I
Test controls and document findings.	A	R	I	C	I
Plan and implement technical remediation.	I	C	A	R	C
Approve risk treatment and accept residual risk.	C	R	C	I	A
Retest controls and report readiness conclusions.	A	R	C	C	I

R = Responsible | A = Accountable | C = Consulted | I = Informed